

Chương 2. Vấn đề phát triển của bảo mật

Mục tiêu bài học

- Hiểu được hệ sinh thái bảo mật
- Hiểu được phương pháp zero-trust
- Hiểu được phương pháp xâm nhập giả định
- Hiểu được sự phát triển tại lớp nền tảng

Nội dung bài học

- Hệ sinh thái bảo mật
- Phương pháp zero-trust
- Phương pháp xâm nhập giả định
- Sự phát triển ở lớp nền tảng

1. Hệ sinh thái bảo mật

- Các tổ chức an ninh và nghiên cứu bảo mật làm việc suốt ngày đêm để phát triển giải pháp hiệu quả nhằm giải quyết các mối đe dọa mới.
- Các tổ chức chi hàng triệu đô la mỗi năm để
 - Nâng cao vị thế và các công cụ bảo mật, như các lỗ hổng zero-day
 - Xây dựng mạng nơ-ron nhân tạo (Artificial neural network - ANN) để bảo vệ thiết bị đầu cuối
 - Tạo ra các mô hình học máy để phát triển sớm các mối đe dọa mới
 - Xây dựng quy trình phản hồi và nhận thức về sự cố an ninh mạng hiệu quả.



1. Hệ sinh thái bảo mật

Có bốn loại chiến lược phòng chống tấn công mạng cơ bản:

- **Giảm bề mặt tấn công:** thường xuyên tiến hành quét lỗ hổng bên ngoài và nội bộ đối với các cổng ứng dụng, thông tin mở rộng và thông tin nền tảng.

Quá trình đánh giá liên tục mối đe dọa bảo mật giúp họ tìm ra câu trả lời cho các câu hỏi sau:

- Chúng ta đang làm gì khác biệt? (công nghệ, quy trình, ứng dụng, con người...)
- Các ứng dụng rủi ro hàng đầu là gì?
- Khoảng trống bảo mật trong hệ thống mạng là gì?
- Người dùng và quy trình rủi ro nhất là gì?

1. Hệ sinh thái bảo mật

- **Khả năng hiển thị hoàn chỉnh:** các phần mềm tổng tiền như WannaCry và NotPetya sử dụng lỗ hổng dựa trên SMB để xâm nhập các thiết bị đầu cuối. Việc phát hiện các tác nhân độc hại giúp phân tích sau khi hệ thống nhiễm mã độc và cải thiện vị thế bảo mật của tổ chức.
- **Ngăn chặn các mối đe dọa đã biết:** chiến tranh mạng giữa chuyên gia bảo mật và tin tặc luôn diễn ra không ngừng. Các cuộc tấn công mạng thường phức tạp và khó lường; tuy nhiên tường lửa và phần mềm chống vi-rút vẫn là giải pháp thiết yếu như là tuyến phòng thủ đầu tiên cho hệ thống mạng và các thiết bị đầu cuối.

1. Hệ sinh thái bảo mật

- **Ngăn chặn các mối đe dọa không xác định:** có những mối đe dọa mới hoạt động như người dùng hợp lệ; do đó, để phát hiện và phản ứng với các mối đe dọa này, các tổ chức đang áp dụng các phương pháp tiếp cận mới như:
 - Phân tích động và hành vi
 - Học máy / học sâu
 - Phân tích kỹ thuật, chiến thuật và tiến trình của kẻ tấn công.

Phần lớn các chuyên gia bảo mật vẫn xử lý với các mối đe dọa như bất kỳ phần mềm độc hại trước kia; tuy nhiên, thực tế là tin tặc đã trở nên tinh vi hơn, có động cơ rõ ràng. Họ tự thực hiện các lệnh, các công cụ và tấn công xâm nhập vào hệ thống mạng từ nhiều cách tiếp cận cùng một lúc.

2. Phương pháp zero-trust

- Một cách tiếp cận được chấp nhận rộng rãi là cách tiếp cận tập trung vào dữ liệu, luôn xác minh cho tất cả dữ liệu và tài sản.
- Cách tiếp cận này khắc phục vấn đề mạng trong thế giới phẳng, giúp tin tặc di chuyển không bị phát hiện để khai thác thông tin nhạy cảm và bí mật.
- Cách tiếp cận này cũng trao quyền cho các chuyên gia bảo mật để họ có thể giành lại quyền kiểm soát mạng và ứng dụng của họ.

2. Phương pháp zero-trust



2. Phương pháp zero-trust

- **Xác định và phân loại dữ liệu nhạy cảm:** nếu bạn không xác định và phân loại được dữ liệu nhạy cảm của mình, tình hình có thể tồi tệ hơn trong giai đoạn hậu nhiễm mã độc.
- **Lập bản đồ luồng dữ liệu:** phải hiểu về luồng ứng dụng trên mạng và hợp tác với tất cả các bên liên quan, bao gồm nhóm mạng, nhóm ứng dụng và kiến trúc sư bảo mật, để chuẩn bị luồng dữ liệu cuối cùng với sự trợ giúp của các mô hình hiện có.
- **Xác định kiến trúc mạng:** Thiết kế zero-trust cho phép các luồng giao tiếp giữa nhiều mạng và cách người dùng có thể truy cập dữ liệu bên ngoài. Ở giai đoạn này, tổ chức sẽ xác định cấu hình chuyển đổi vật lý và ảo.
- **Tạo cơ sở chính sách:** các chuyên gia bảo mật nên hạn chế quyền truy cập trên cơ sở kiểm soát truy cập hiệu quả. Ngoài việc biết các trường trong tiêu đề IP, các nhóm bảo mật cũng cần biết định danh người dùng cũng như hành vi thao tác với ứng dụng.
- **Giám sát liên tục:** Toàn bộ mạng và nhật ký ứng dụng phải được thu thập và kiểm tra trong thời gian thực, bao gồm không chỉ lưu lượng truy cập từ mạng bên ngoài, mà còn lưu lượng truy cập đi ra khỏi mạng nội bộ. Lưu lượng truyền thông nội bộ nên được xử lý giống như cách xử lý lưu lượng truyền thông bên ngoài.

3. Phương pháp xâm nhập giả định

- Ngay cả với các hệ thống ngăn chặn tấn công mạng ngày càng phát triển, bao gồm hệ thống phòng tránh vi-rút, tường lửa..., các mối đe dọa mới vẫn có thể vượt qua hệ thống bảo mật.
- Không có công nghệ phòng ngừa bảo mật nào có thể đảm bảo bảo vệ hoàn toàn chống lại các mối đe dọa như vậy.
- Trong vài năm qua, các tổ chức đã áp dụng một cách tiếp cận mới được gọi là giả định xâm nhập, đó là một cách để kiểm tra năng lực ứng phó sự cố của họ.

3. Phương pháp xâm nhập giả định

Phương pháp xâm nhập giả định cho phép các tổ chức thử nghiệm các giải pháp và dịch vụ bảo mật khác nhau, cụ thể:

- **Bài tập Red-team:** là phiên bản nâng cao của thử nghiệm xâm nhập, được thực hiện bởi một nhóm các chuyên gia bảo mật chuyên nghiệp để tìm lỗ hổng và kiểm tra khả năng phát hiện và ứng phó sự cố của tổ chức, giúp quản lý cấp cao của tổ chức sử dụng các khuyến nghị chiến thuật để cải thiện ngay lập tức và đưa ra các khuyến nghị chiến lược để cải thiện vị thế bảo mật lâu dài.
- **Giám sát liên tục:** cung cấp khả năng hiển thị theo thời gian thực của người dùng và thiết bị đầu cuối trong mạng doanh nghiệp, giúp xác định các mối đe dọa ở giai đoạn tiền nhiệm và xây dựng quy trình ứng phó sự cố tốt hơn. Hầu hết các tổ chức có xu hướng thuê các nhà cung cấp dịch vụ bảo mật được quản lý (Managed security service - MSS), những người giám sát mạng, ứng dụng và hoạt động người dùng thông qua các công cụ thông dụng như: thông tin bảo mật và quản lý sự kiện (SIEM), phát hiện và phản hồi thiết bị đầu cuối (EDR).

3. Phương pháp xâm nhập giả định

Security Governance Models

1. Assume Breach
2. Defense in Depth
3. Risk-based Approach
4. Detection and Response
5. Continuous Improvement



4. Sự phát triển ở lớp nền tảng

- Toàn bộ hệ thống an ninh mạng được thiết kế để bảo vệ mạng máy tính chạy trên mô hình TCP/IP và sử dụng kiến trúc cơ sở dữ liệu máy khách-máy chủ. Nếu máy chủ bị xâm nhập, tất cả dữ liệu có thể bị thay đổi, bị loại bỏ hoặc thậm chí bị xóa.
- Phần lớn các sự cố xâm nhập dữ liệu ảnh hưởng lớn đến với cơ sở dữ liệu máy chủ tập trung trên cloud. Ở các chương tiếp theo, bạn sẽ tìm hiểu cách giải quyết vấn đề quan trọng này với công nghệ Blockchain.

5. Kết luận

- Trong chương này, bạn đã tìm hiểu về cách các chuyên gia bảo mật đang cập nhật sự đổi mới trong thế giới an ninh mạng.
- Bạn cũng đã tìm hiểu về một số phương pháp và tư duy bảo mật hiệu quả nhất và được sử dụng rộng rãi.
- Cuối cùng, chúng ta phải nhìn vào những thách thức bảo mật ở lớp nền tảng hiểm khi được giải quyết.
- Trong chương tiếp theo, bạn sẽ tìm hiểu về Blockchain, khối xây dựng, làm việc và vai trò của blockchain trong kỷ nguyên mới.

Assessment

Câu 1. Lỗ hổng zero-day là gì ?

- A. Lỗ hổng chưa từng được ghi nhận.
- B. Lỗ hổng không đáng kể
- C. Lỗ hổng chỉ xuất hiện vào một ngày xác định
- D. Lỗ hổng đã từng được ghi nhận.

Assessment

Câu 2. Các chiến lược phòng chống tấn công mạng cơ bản ?

- A. Giảm bề mặt tấn công.
- B. Hiện thị hoàn chỉnh
- C. Ngăn chặn các mối đe dọa đã biết
- D. Ngăn chặn các mối đe dọa không xác định.
- E. Tất cả 4 câu trên đều đúng

Assessment

Câu 3. Phương pháp zero-trust là gì ?

- A. Tập trung vào dữ liệu, luôn xác minh cho tất cả dữ liệu và tài sản.
- B. Xác thực một lần, và cho phép người dùng truy cập toàn bộ dữ liệu.
- C. Xác thực đa yếu tố.
- D. Xác thực một yếu tố.

Assessment

Câu 4. Các bước nào sau đây nằm trong phương pháp zero-trust ?

- A. Xác định và phân loại dữ liệu nhạy cảm, lập bản đồ luồng dữ liệu, xác định kiến trúc mạng, tạo cơ sở chính sách, giám sát liên tục.
- B. Bài tập Red team, xác định và phân loại dữ liệu nhạy cảm, lập bản đồ luồng dữ liệu, xác định kiến trúc mạng, giám sát liên tục.
- C. Xác định và phân loại dữ liệu nhạy cảm, xác thực đa yếu tố, xác định lỗi Zero-day, lập bản đồ luồng dữ liệu, giám sát liên tục.
- D. Cả 3 câu trên đều đúng.

Assessment

Câu 5. Phương pháp xâm nhập giả định là gì ?

- A. Phương pháp cho phép các tổ chức thử nghiệm các giải pháp và dịch vụ bảo mật khác nhau, để kiểm tra năng lực ứng phó sự cố.
- B. Tập trung vào dữ liệu, luôn xác minh cho tất cả dữ liệu và tài sản.
- C. Phương pháp xác định và tấn công vào hệ thống mạng của tin tặc.
- D. Tất cả các câu trên đều đúng.

Assessment

Câu 6. Các bước nào sau đây nằm trong phương pháp xâm nhập giả định ?

- A. Bài tập Red-team, Giám sát liên tục.
- B. Bài tập Red-tea, xác định và phân loại dữ liệu nhạy cảm.
- C. Giám sát liên tục , xác định và phân loại dữ liệu nhạy cảm.
- D. Cả 3 câu trên đều đúng.

